

Managing Vulnerabilities in Software Libraries (and sandwiches)

Justin Hall
Tenable Research

Greetings! I'm Justin



IT since 1996

Infosec since 2005

Blue → Red → Purple → Silver

Husband

Dad

UC Bearcat

Former Sandwich Artist



LIBCURL

IS THIS AN APP?

What is a Software Library?

- An individual, reusable component
- A foundation of modern software development
- Ex: libcurl is a library
 - Distinct from Curl, the app
- **Requires another app to use it; can't be launched on its own**
- Can have vulnerabilities just like full apps can

Why the growth in library vulns?

- Greater focus from researchers and attackers
 - Libraries have been often overlooked
 - Maintainers are overworked and underappreciated
 - Breaking one library could give you attack surface on many applications

What about “language” libraries?

- Python, Node.JS, Ruby, Go, Java, etc
- Libraries installed manually, or by package managers
 - pip, npm, gem, maven

Ex: CVE-2023-29483, DoS vuln in dnspython

Log4j – the OG library vuln

- Dec 9, 2021 - CVE-2021-44228 set the internet on fire
- Used inside of **thousands of apps** for logging
- Feed a string that gets logged to app that uses it, ingested and parsed by the library
- String can contain RCE code

Major library vulnerabilities in '23/24

- Libcurl - CVE-2023-38545/CVE-2023-38546
- Libwebp - CVE-2023-4863
- Libssl - CVE-2023-0464
- Liblzma - CVE-2024-3094

These libraries are used collectively by **hundreds of thousands** of pieces of software!

Poll Time!

- Do you maintain a software inventory on your assets?

Poll Time!

- Do you maintain a software inventory on your assets?
- Does that inventory include components and libraries?

Poll Time!

- Do you maintain a software inventory on your assets?
- Does that inventory include components and libraries?
- Do you expect your vulnerability management tools to notify you about component and library vulnerabilities?

Demo time!



Libraries == Condiments

- Libraries enhance applications, adding new and interesting flavors and textures, often differentiating them from others or becoming a core feature
- Helpful for functionality, not used as a standalone product
- From a risk perspective, **distinct** from full apps due to **more complex exploitation requirements**

Making your own sandwiches

Software Development Teams!

- You are responsible for keeping libraries “fresh”
 - This should be a role assigned to one or more devs, PMs or managers
 - Stale or expired libraries will spoil your apps



Software Development Teams!

- Anticipate vulnerabilities
 - Document each project's core dependencies
 - Develop a generalized response plan if a vulnerability arises
 - If needed, build specific plans for key library dependencies

Software Development Teams!

- Anticipate vulnerabilities
 - How will we know library has been updated?
 - How do we ensure updated library will be compatible?
 - Plans should include contingencies if a library must be replaced or removed
 - This should be in your Governance risk inventory!

**Go pick up a
sandwich**

Third Party Library Vuln Management

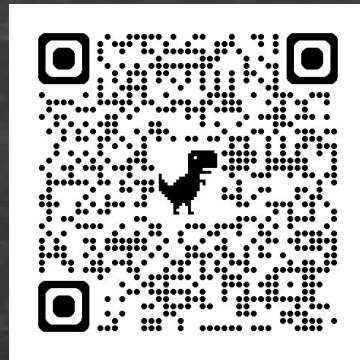
- Maintain an authorized software list
 - a SBOM for each application is helpful
- Regular checks for vulnerabilities
- Communication with vendors and developers about updates

Let's talk about SBOMs

- This is why they're useful!
- Value comes from understanding the risk of using a particular application
- Must have alternatives prepared and a plan to engage them

SLSA – slsa.dev

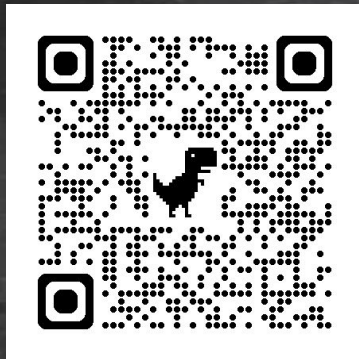
- Supply chain Levels for Software Artifacts
- A framework for software supply chain security
- Tenable Nessus is SLSA level 1



Thoughts from the VM world

- How do customers want to see libraries in their asset view?
- How do they want to scan for libraries?
- How do they want to see vulnerabilities?

Thanks!



@justinhall